COMPUTERS & SECURITY 86 (2019) 132–146

Available online at www.sciencedirect.com

ScienceDirect

journal homepage: www.elsevier.com/locate/cose

Computers & Security

Anonymous authentication scheme for smart home environment with provable security

Mengxia Shuai[a,*], *Nenghai Yu*[a], *Hongxia Wang*[b], *Ling Xiong*[c]

[a] *CAS Key Laboratory of Electromagnetic Space Information, University of Science and Technology of China, Hefei 230026, China*

[b] *College of Cybersecurity, Sichuan University, Chengdu 610065, China*

[c] *School of Computer and Software Engineering, Xihua University, Chengdu 610039, China*

ARTICLE INFO

Article history:
Received 27 November 2018
Revised 14 May 2019
Accepted 5 June 2019
Available online 12 June 2019

Keywords:
Smart home
Elliptic curve cryptography
Authentication
Lightweight
Provable security

ABSTRACT

Smart home is an emerging paradigm of the Internet of Things (IoT), which facilitates an individual to operate the smart home appliances remotely through the internet. Since the user and the smart devices communicate over insecure communication channels, the transmitted sensitive data collected by the smart devices may be intercepted and altered easily by a malicious adversary. Therefore, there is a great need to design an effective and anonymous authentication scheme to guarantee secure communications in smart home environment. In the past decade, extensive research has been carried out on this security issue, but most of them are not secure. As a step towards this direction, in this paper, we propose an efficient and anonymous authentication scheme for smart home environment using Elliptic Curve Cryptography (ECC). The proposed scheme avoids keeping the verification table for authentication purposes. In addition, random number method is adopted to resist replay attack, and it can avoid the clock synchronization problem. The rigorous formal proof and heuristic analysis show that the proposed scheme provides the desired security features and resists against all the possible attacks. Compared with the most representative related schemes, the proposed scheme achieves a delicate balance between security and efficiency, and it is more suitable for realistic environments.

© 2019 Elsevier Ltd. All rights reserved.

1. Introduction

With the rapid development of wireless communication and sensor technology, smart home is emerging rapidly as an exciting new paradigm of Internet of Things (IoT), and it has attracted continuing attention from both academia and industry field. In a smart home environment, advanced automation systems are incorporated to provide the inhabitants with new smart functions and services, like reducing operational costs, increasing comfort and guaranteeing the safety of the inhabitants. The interconnected smart devices in this context can be lighting sensors, humidity sensors, occupancy sensors, temperature sensors, and even monitoring equipments. Based on these smart devices, different types of services can be provided. For example, if the owner opens the door and enters the house, the light control system starts working and turns on the lights in the home. Then, the occupancy of the home can be sensed using smart meters (Jin et al., 2017) and environmental sensors like CO_2 sensors, which can be integrated to trigger automatic responses for energy efficiency and building comfort applications (Jin et al., 2016). In addition, smart

* Corresponding author.
E-mail addresses: smx12345@mail.ustc.edu.cn (M. Shuai), ynh@ustc.edu.cn (N. Yu), hxwang@scu.edu.cn (H. Wang), lingdonghua99@163.com (L. Xiong).

https://doi.org/10.1016/j.cose.2019.06.002
0167-4048/© 2019 Elsevier Ltd. All rights reserved.

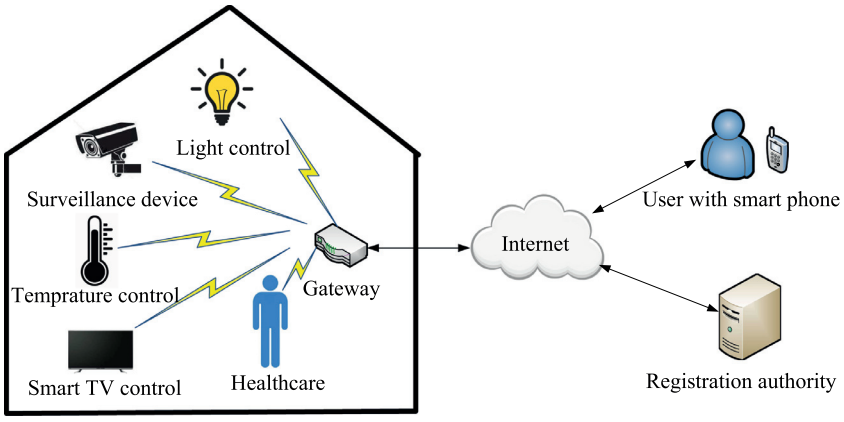


Fig. 1 – Typical architecture of smart home environment.

home can also provide the convenient and efficient healthcare delivery for the elderly and disabled people using smart gadgets (Gomez and Paradells, 2010; Suryadevara et al., 2013). Using any suitable device such as smart phone, the end user can operate the smart home appliances remotely with no limitations on space and time.

A typical architecture of smart home environment is depicted in Fig. 1, adapted from Kumar et al. (2015) and Wazid et al. (2017). The network model consists of four entities namely the smart devices in the home, gateway node (*GWN*), the end user and registration authority (*RA*). The smart devices are heterogeneous and resource-constrained mostly, and they can be used to enable a variety of use cases (Gomez and Paradells, 2010), such as lighting control, surveillance system, temperature control, etc. The *GWN* deployed in the home is a powerful master node and serves as a bridge between the user and the smart devices (Wazid et al., 2017; Xue et al., 2013). The user can control the heterogeneous smart home devices remotely as per their requirements. The *RA* has high computation and communication capabilities and fully trusted by others. It is responsible for accomplishing the following tasks: (i) generating system parameters and assigning them to all involved entities. (ii) The user and the smart devices registration. (iii) Key management and maintenance.

Although smart home brings great convenience to people's lives, the security has always been a critical issue. Due to the open feature of wireless channel, the transmitted messages may be intercepted and altered easily by a malicious adversary. Thus the exchanged information needs to satisfy the requirements of confidentiality, integrity, and availability. Moreover, authentication schemes only employing symmetric cryptographic operations, such as hash functions, symmetric encryption and XOR operations, are unable to achieve some advanced security features like user anonymity. As deeply investigated in the work (Wang and Wang, 2014b), public-key techniques are indispensable to resist against user anonymity violation attack under the non-tamper resistance assumption of the smart cards. On the other hand, most of the smart devices in the home are resource-constrained and have characteristics such as limited battery backup, limited computational and communication power. Therefore, the traditional public-key cryptosystems, such as Diffie–Hellman and Rivest–Shamir–Adleman (RSA), are not suitable and lightweight authentication schemes are necessary. The characteristics of low arithmetic requirements, small key size and shorter operand length indicate Elliptic Curve Cryptography (ECC) as a viable solution for guaranteeing secure communications in smart home environment.

1.1. *Related work*

Until now, a large number of authentication schemes had been proposed for smart home environment. In 2008, Jeong et al. (2008) proposed an one-time password (OTP) based user authentication scheme for home networks using smart cards, in which the authors claimed that the scheme was lightweight and withstood various attacks. However, mutual authentication between *GWN* and the smart device was not provided, and user anonymity was also not achieved because the real identity of the user was sent in plaintext. Furthermore, their scheme suffered from privileged–insider attack and stolen smart card attack. In order to provide secure remote access in digital home network environments, Vaidya et al. (2011b) presented a remote authentication scheme using lightweight computation modules, such as low-cost smart card technology, hashed one-time password and hash-chaining technique. They claimed that their scheme provided important security features and was resistant to multiple types of attacks. Unfortunately, Kim and Kim (2011) pointed out that Vaidya et al.'s (2011b) scheme was not only vulnerable to password guessing attack, but also failed to provide user anonymity and forward secrecy. In addition, mutual authentication between *GWN* and the smart device was also not provided. To strengthen the security, an improved authentication scheme was proposed subsequently, in which all identified security flaws in Vaidya et al.'s (2011b) scheme were eliminated. Later, Vaidya et al. (2011a) also presented a device authentication mechanism for smart energy home area network using ECC. Soon after this scheme was proposed, it was found to possess some security weaknesses, such as privileged-insider attack, password guessing attack and user impersonation attack. In order to deliver the services to the user devices securely, Pradeep and Singh (2012) designed a secure three way authentication method for ubiquitous computing devices, in which the users or the service providers could check whether

the device was compromised or not by the help of their encrypted pass-phrases method.

In order to deal with the security problem of smart home energy management systems, a lightweight key establishment protocol was proposed by Li (2013), and an initial session key was established between the wireless nodes and control center. Besides, the implementation and evaluation results of the protocol were presented. However, Li's scheme was not scalable since the management of a large number of keys and certificates was required. Besides, the security analysis of their scheme was very limited. Moreover, mutual authentication between user and wireless nodes as well as between user and control center was not provided in their scheme. In the same year, Han et al. (2013) presented a key agreement protocol to bring secure pairing process for radio frequency for consumer electronics (RF4CE) ubiquitous smart home systems. In their scheme, the initial unique secure information was pre-shared between consumer devices (targets) and manufacturers, and remote controller could receive the secret information of the device by communication with the manufacturers. However, their scheme was unrealistic because it required the manufacturers to keep always online. Similar to Li's (2013) scheme, their scheme did not provide mutual authentication between user and consumer devices as well as between user and remote controller.

In 2015, Santoso and Vun (2015) proposed a secure authentication scheme for smart home system using ECC, in which a wifi gateway was used as the center node of the system to perform the mutual authentication between the mobile user and the smart device. However, user anonymity and untraceability were not provided in their scheme. Furthermore, their scheme suffered from privileged–insider attack and stolen smart card attack. In the same year, Kumar et al. (2015) proposed a lightweight authentication and key agreement scheme for smart home environments. In their scheme, a session key was established between *GWN* and smart device by using a short authentication token. Unfortunately, it was found that the anonymity and untraceability were not preserved. In addition, similar to Li's (2013) scheme and Han et al.'s (2013) scheme, mutual authentication between user and smart device as well as between user and *GWN* was not provided in their scheme. To mitigate the aforementioned issues, Wazid et al. (2017) proposed a new secure remote user authentication scheme for smart home environment. The scheme in Wazid et al. (2017) was efficient for resource-constrained smart devices because it used only the lightweight cryptographic primitives, such as symmetric encryption/decryption operations and one–way hash functions. However, we found that their scheme suffered from desynchronization attack. In addition, a verification table was kept in *GWN* side for the purpose of authentication, and it was disastrous if the verification table was stolen by an adversary. What's more, the time stamp mechanism was used to avoid replay attack in their scheme, and it might encounter clock asynchronization problem.

1.2. *Adversary model*

The Dolev–Yao model (Dolev and Yao, 1983), which is widely used to prove properties of interactive cryptographic protocols, is adopted to evaluate the security of the proposed scheme. Under this model, the communications between any two communicating parties are over an insecure channel, and the endpoint entities should not be considered as trusted entities. Based on this threat model, an adversary $\mathscr{A}$ is supposed to have the following capacities:

(1) $\mathscr{A}$ can fully control the open communication channel, i.e., $\mathscr{A}$ can intercept, modify, insert and delete the transmitted messages over open channels.
(2) When the mobile device of user was stolen or obtained by an attacker $\mathscr{A}$, then the secret values stored in the mobile device can be revealed by $\mathscr{A}$ using side-channel attacks (Alkhoraidly et al., 2012; Barenghi et al., 2009; Kocher et al., 1999; Messerges et al., 2002; Mulder et al., 2005; Spreitzer et al., 2017).
(3) $\mathscr{A}$ is a probabilistic polynomial time attacker. In other words, $\mathscr{A}$ can guess the low-entropy password and identity information within polynomial time.
(4) The smart device equipped in smart home environment is not tamper-resistant and may be captured physically by $\mathscr{A}$, and all the sensitive data stored in the smart device can be extracted.
(5) The registration authority is fully trusted, and it can not be compromised by $\mathscr{A}$.
(6) $\mathscr{A}$ may be a legitimate but malicious user.

1.3. *Security requirements*

Since all information in smart home environment is transmitted over open channels, the authentication scheme may suffer from lots of attacks. To guarantee secure communication, a secure, robust, and efficient authentication scheme is needed. Based on previous works (Kumar et al., 2015; Wazid et al., 2017), we believe that authentication scheme for smart home environment should meet the following security properties.

Mutual authentication. In order to allow only authorized users to access smart device's sensitive data as per their requirements, mutual authentication among the user, *GWN*, and the smart device is needed (He and Zeadally, 2015). This can be achieved with the help of *GWN*.

Session key agreement. After mutual authentication, the data transmitted between the user and the smart device should be encrypted using the shared session key. Therefore, the proposed scheme should provide session key agreement.

User anonymity. User anonymity is an important security feature of authentication scheme for smart home environment. If an adversary $\mathscr{A}$ gets the real identity of the user, the privacy of the user will be violated.

Untraceability. Authentication scheme for smart home environment should not only provide user anonymity, but also achieve user untrackability. User untrackability guarantees the adversary neither determining who the user is nor telling apart whether two sessions are executed by the same user (Wang and Wang, 2014a).

No verification table. In most of the previously proposed authentication schemes, *GWN* should keep a verification table for authentication. It is disastrous if the verification table is stolen by an adversary, so the proposed scheme should avoid keeping the verification table for the purpose of authentication.

Avoid of clock synchronization problem. Since the clock synchronization is a big challenge in smart home environment, the proposed scheme should avoid using the time stamp to resist replay attack. As can be seen from the existing literature (Chuang and Lee, 2011; Esfahani et al., 2017; Xu et al., 2018), the random number method can be adopted to ensure the freshness of exchanged messages.

Quickly detection for unauthorized login. To avoid the waste of computation and communication resources for invalid login, it is necessary to check the correctness of the password in the user login phase.

Attacks resistance. To ensure secure communication in smart home environment, the designed authentication scheme is able to resist various attacks, liking mobile device loss attack, replay attack, privileged-insider attack, man-in-the-middle attack and impersonation attack.

1.4. Contributions

The major contributions of this paper can be summarized as follows:

(1) The network model, adversary model and security requirements of authentication scheme for smart home environment are depicted, which are the basis of the authentication scheme and ignored by researchers usually.
(2) An efficient and anonymous authentication scheme for smart home environment using ECC is proposed to conquer the drawbacks of the historical protocols. The proposed scheme avoids keeping the verification table for authentication purposes and allows three types of mutual authentications: (i) between the user and *GWN*, (ii) between *GWN* and the smart device, and (iii) between the user and the smart device. Finally, a symmetric session key *SK* is established between the user and the smart device, which is used for future secure communications.
(3) The rigorous formal proof and detailed security analysis demonstrate that the proposed scheme can not only agree on a session key for future secure communications, but also achieve more functional features and resist various kinds of known attacks.
(4) The performance analysis shows that the proposed scheme achieves a delicate balance between security and efficiency, and it is applicable to realistic environments.

1.5. Organization of the paper

The reminder of this paper is organized as follows. The preliminary knowledge is introduced in Section 2. In Section 3, we present an efficient ECC-based authentication scheme for smart home environment. Security analysis and performance analysis of the proposed scheme are given in Section 4 and Section 5, respectively. Finally, Section 6 concludes this paper.

Table 1 – Notations and abbreviations.

Notation	Descriptions
ECC	Elliptic curve cryptography
U_i	Remote user
GWN	Gateway node
SD_k	Smart device in the home
ID_i	Unique identity of U_i
PW_i	Password of U_i
DID_i	Pseudonym identity of U_i
GID_j	Unique identity of *GWN*
SID_k	Unique identity of SD_k
RA	Registration authority
K	Master secret key of *GWN*
SK	Session key
R_1, R_2, R_3, a	Random numbers
$h(.)$	One-way hash function
$X\|\|Y$	Concatenate operation
$\oplus$	XOR operation

2. Preliminaries

This section briefly describes elliptic curve cryptography and the hash function.

2.1. Notations

For convenience, all the notations mentioned in the proposed scheme are defined in Table 1.

2.2. Elliptic curve cryptography

ECC is a public key encryption method based on the algebraic structure of elliptic curves over finite fields. Compared with previous conventional cryptographic techniques, such as RSA and Diffie–Hellman, it has been proved that ECC is more efficient cryptographic technique for security. Given a prime number p, an elliptic curve $E(F_p)$ is defined by the equation $y^2 = x^3 + a \cdot x + b mod p$, in which $a, b \in F_p$ and $\triangle = 4a^3 + 27b^2 \neq 0 mod p$. All the points on the elliptic curve E and the infinite point O make up an additive group G with the order q. Given a generator P of the group G, the scale multiplication operation is defined as $n \cdot P = P + P + ... + P$ ($n$times), where $n \in Z_p$ as a positive integer.

The following problem in the group G is suitable for designing public key cryptography because there is no probabilistic polynomial time algorithm that can effectively solve it.

Elliptic Curve Discrete Logarithm Problem (ECDLP). Suppose $x \in Z_p^*$ is a positive integer and $\{X, P\} \in G$ are two points on the elliptic curve. Given the equation $X = x \cdot P$, the Elliptic Curve Discrete Logarithm Problem (ECDLP) is to determine x given X and P. It is computationally easy to calculate X given x and P, but it is infeasible to compute x given X and P, when the prime number p is large.

2.3. Hash function

Hash function is a one-way function which can be used to map data of arbitrary size to data of a fixed size. In order to ensure the security, an one-way hash function $X = h(x)$ should have the following properties:

(1) Given a message x of arbitrary-length, hash function $h(x)$ produces a fixed-size output.
(2) For any given x, $h(x)$ is relatively easy to compute.
(3) For any given hash value X, it is computationally infeasible to find x making $X = h(x)$.
(4) For any given x, it is computationally infeasible to find $y \neq x$ with $h(y) = h(x)$.
(5) It is computationally infeasible to find any pair (x, y) making $h(x) = h(y)$.

3. The proposed scheme

In this section, an efficient ECC-based authentication scheme for smart home environment is presented, which not only withstands all know passive and active attacks, but also achieves the desirable functional features. The proposed scheme includes five phases, i.e. initialization phase, registration phase, login and authentication phase, and password change phase.

3.1. Initialization phase

The initialization phase is done by the *RA* securely. First of all, *RA* selects an elliptic curve E based on a finite field F_p and chooses an additive group G of E with order q, and P is a generator of G. After that, *RA* generates the system private key $x \in Z_q^*$ and calculates the system public key $X = x \cdot P$. Then, *RA* chooses a long-term secret key K and a hash function $h(.) : \{0, 1\}^* \rightarrow Z_q^*$. Further, *RA* stores x and K into the memory of *GWN* secretly and publishes the parameters $\{E(F_p), G, P, X, h(.)\}$. At last, *RA* selects a random number SID_k as the unique identity of the smart device SD_k and stores it into the memory of SD_k. It should be noted that the parameters $\{E(F_p), G, P, X, h(.)\}$ are known by all users and preloaded into *GWN* and all the smart devices.

3.2. Registration phase

The registration phase of the proposed scheme contains two parts, i.e., user registration phase and the smart device registration phase.

3.2.1. User registration phase

To access the sensitive data collected by smart devices, each user has to register with *RA* firstly. Fig. 2 shows the user registration phase.

(1) A new user U_i selects the identity ID_i, the password PW_i, and generates a random nonce a. Then the user U_i computes $HPW_i = h(PW_i||a)$ and sends $\{ID_i, HPW_i\}$ to *RA* via a secure channel.
(2) Upon receipt of the registration message, *RA* first checks whether ID_i exists in the user information table. If yes, *RA* asks U_i to submit a new identity. Otherwise, *RA* computes $K_{GU} = h(ID_i||K)$, $A_1 = K_{GU} \oplus HPW_i$. After that, *RA* generates a random value *TEMP* to record the number of user login failures, and the value of *TEMP* is initialized to 0. Then, *RA* sends the data $\{A_1, TEMP\}$ to U_i via a secure channel.
(3) After receiving the data from *RA*, U_i computes $A_2 = a \oplus h(ID_i||PW_i)$, $A_3 = h(ID_i||HPW_i)$ and writes A_2, A_3 into the mobile device. Then the mobile device contains $\{A_1, A_2, A_3, TEMP\}$.

3.2.2. The smart device registration phase

The procedure of the smart device's registration is outlined as follows:

(1) The smart device SD_k transmits the identity SID_k to *RA* via a secure channel.
(2) Upon receiving the identity SID_k, *RA* first checks whether SID_k exists in the smart device information table. If it exists, *RA* refuses the smart device registration request. Otherwise, *RA* computes $K_{GS} = h(SID_k||K)$ and sends K_{GS} to SD_k via a secure channel.
(3) Upon receiving the message from *RA*, SD_k stores K_{GS} into its memory secretly.

3.3. Login and authentication phase

If the user U_i wants to access the real time data of the smart device SD_k with identity SID_k, mutual authentication between all parties (i.e. U_i, *GWN* and SD_k) should be performed, and a session key SK is established between the user U_i and the smart device SD_k for future secure communications. As shown in Fig. 3, the procedure of login and authentication phase is described as follows:

(1) U_i provides the identity ID_i and the password PW_i into the terminal of mobile device. Then the mobile device computes $a^* = A_2 \oplus h(ID_i||PW_i)$, $HPW_i^* = h(PW_i||a^*)$, $A_3^* = h(ID_i||HPW_i^*)$ and checks if $A_3^* = A_3$. If it is not hold, the mobile device rejects the login request and sets *TEMP* to be $TEMP + 1$. If the value of *TEMP* exceeds a predetermined threshold, such as 3, the mobile device has been considered to be breached, and it is suspended till U_i re-registers. Otherwise, the mobile device generates two random numbers R_1 and $w \in Z_n^*$, and U_i chooses the smart device SD_k with the identity SID_k that he/she wants to access. After that, the mobile device computes $K_{GU} = A_1 \oplus HPW_i$, $A_4 = w \cdot P$, $A_5 = w \cdot X$, $DID_i = ID_i \oplus A_5$, $M_1 = (R_1||SID_k) \oplus K_{GU}$, $V_1 = h(ID_i||R_1||K_{GU}||M_1)$. Then, U_i transmits the login message $\{DID_i, A_4, M_1, V_1\}$ to *GWN* through a public channel.
(2) When receiving the login request, *GWN* first computes $A_5^* = x \cdot A_4$ using the stored secret value x. Then, *GWN* computes $ID_i^* = DID_i \oplus A_5^*$, $K_{GU} = h(ID_i^*||K)$, $R_1^*||SID_k = M_1 \oplus K_{GU}$, $V_1^* = h(ID_i^*||R_1^*||K_{GU}||M_1)$, and checks if $V_1^* = V_1$. If it is not hold, *GWN* terminates the session. Otherwise, *GWN* believes the legitimacy of the user U_i. Then,

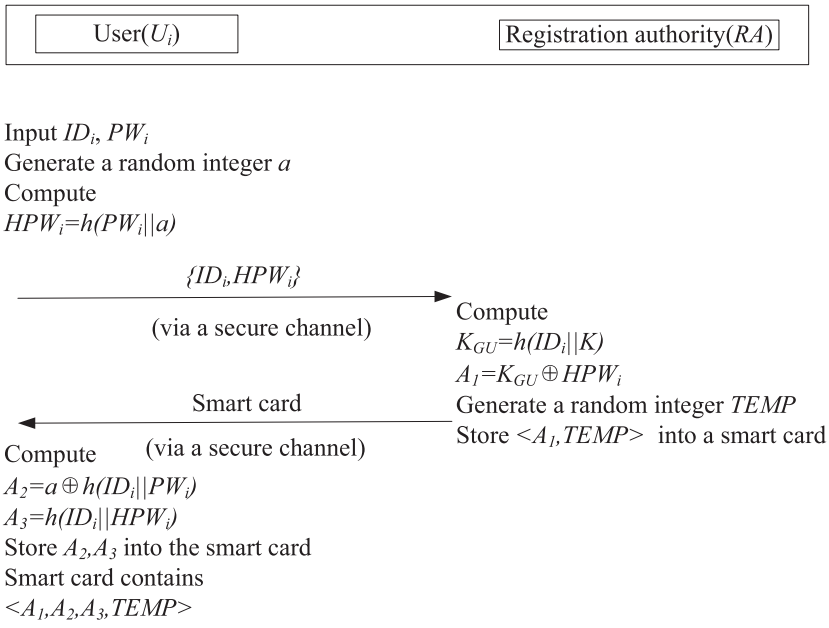


Fig. 2 – The user registration phase of the proposed scheme.

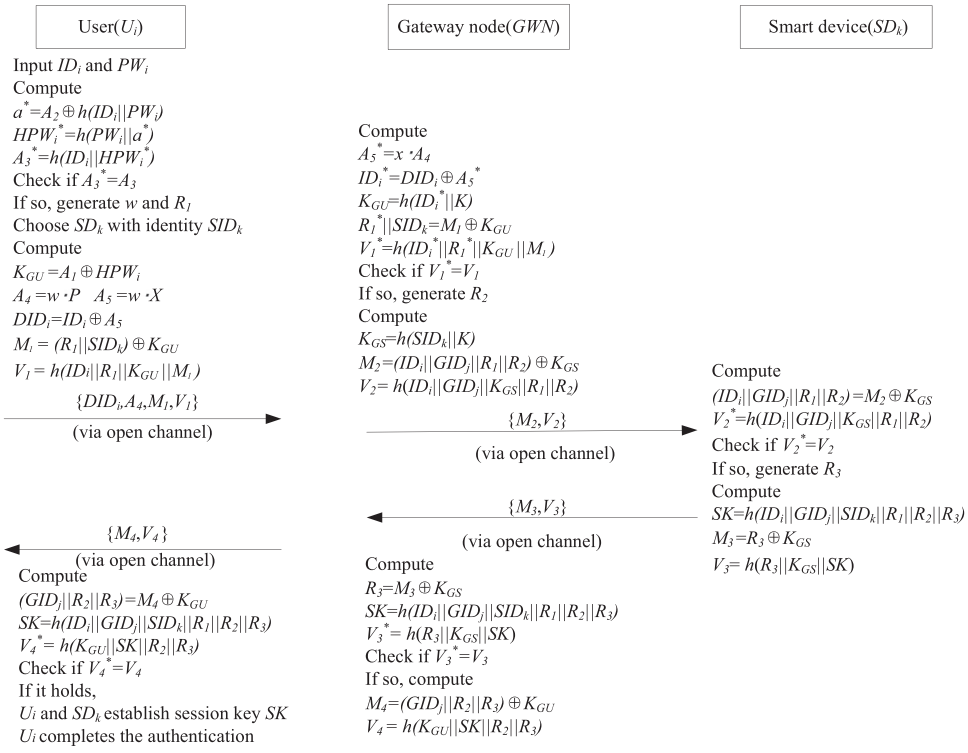


Fig. 3 – Login and authentication phase of the proposed scheme.

GWN generates a random number R_2 and computes $K_{GS} = h(SID_k||K)$, $M_2 = (ID_i||GID_j||R_1||R_2) \oplus K_{GS}$, $V_2 = h(ID_i||GID_j||K_{GS}||R_1||R_2)$. Finally, GWN sends the message $\{M_2, V_2\}$ to the smart device SD_k via public channel.

(3) Upon receiving the message, SD_k computes $(ID_i||GID_j||R_1||R_2) = M_2 \oplus K_{GS}$, $V_2^* = h(ID_i||GID_j||K_{GS}||R_1||R_2)$, and checks if $V_2^* = V_2$. SD_k terminates the session if $V_2^* \neq V_2$. Otherwise, SD_k generates a random number R_3 and computes $SK = h(ID_i||GID_j||SID_k||R_1||R_2||R_3)$, $M_3 = R_3 \oplus K_{GS}$, $V_3 = h(R_3||K_{GS}||SK)$. Then, SD_k transmits the message $\{M_3, V_3\}$ to GWN through a public channel.

(4) After getting the message from SD_k, GWN computes $R_3 = M_3 \oplus K_{GS}$, $SK = h(ID_i||GID_j||SID_k||R_1||R_2||R_3)$, $V_3^* = h(R_3||K_{GS}||SK)$, and checks if $V_3^* = V_3$. The session is terminated if $V_3^* \neq V_3$. Otherwise, GWN computes $M_4 =$

$(GID_j||R_2||R_3)\oplus K_{GU}$, $V_4 = h(K_{GU}||SK||R_2||R_3)$ and sends the message $\{M_4, V_4\}$ to U_i.

(5) When getting the message from GWN, U_i computes $(GID_j||R_2||R_3) = M_4 \oplus K_{GU}$, $SK = h(ID_i||GID_j||SID_k||R_1||R_2||R_3)$, $V_4^* = h(K_{GU}||SK||R_2||R_3)$ and checks if $V_4^* = V_4$. The session is terminated if $V_4^* \neq V_4$. Otherwise, SD_k is authenticated by U_i, and a session key SK is established between the user U_i and the smart device SD_k.

3.4. Password change phase

In this section, the user U_i can change his/her password without any interaction with GWN by performing the following operations.

(1) U_i provides the identity ID_i and the password PW_i into the terminal of mobile device.

(2) The mobile device computes $a^* = A_2 \oplus h(ID_i||PW_i)$, $HPW_i^* = h(PW_i||a^*)$, $A_3^* = h(ID_i||HPW_i^*)$ and checks if $A_3^* = A_3$. If it is not hold, the mobile device rejects the password change request. Otherwise, the mobile device believes the legitimacy of U_i and allows U_i to input a new password PW_i^{new}.

(3) The mobile device computes $HPW_i^{new} = h(PW_i^{new}||a^*)$, $A_1^{new} = K_{GU} \oplus HPW_i^{new} = A_1 \oplus HPW_i \oplus HPW_i^{new}$, $A_2^{new} = a^* \oplus h(ID_i||PW_i^{new})$, $A_3^{new} = h(ID_i||HPW_i^{new})$. At last, A_1^{new}, A_2^{new} and A_3^{new} are stored in the mobile device to replace A_1, A_2 and A_3, respectively.

4. Security analysis of the proposed scheme

In this section, we first give the formal proof of the proposed scheme under random oracle model. After that, we conduct a formal security analysis using Burrows–Abadi–Needham (BAN) logic to demonstrate that the proposed scheme achieves mutual authentication successfully. Then, we demonstrate that the proposed scheme provides mutual authentication and session key security using automatic cryptographic protocol verifier tool ProVerif (Blanchet, 2001). In addition, we demonstrate that the proposed scheme can resist all known attacks and provide the desired security features. Furthermore, we compare the functionality and security features among the proposed scheme and four prior related schemes, i.e., Kumar et al.'s (2015) scheme, Wazid et al.'s (2017) scheme, Li's (2013) scheme and Han et al.'s (2013) scheme.

4.1. Formal security analysis using random oracle model

In this subsection, we give the formal proof of the proposed scheme under the widely-accepted random oracle model (Abdalla et al., 2005).

4.1.1. Basic knowledge of formal proof

There are three participants in the proposed scheme $\mathcal{P}$, one user U_i, one gateway node GWN, and one smart device SD_k. Each participant has many instances, and each instance is treated to be an oracle.

Protocol participants. Let $\prod_{U_i}^u$, $\prod_{GWN}^v$ and $\prod_{SD_k}^t$ be the instances u, v and t of U_i, GWN and SD_k, respectively.

Accepted state. If the last expected protocol message is received, an instance $\prod^t$ goes into an accepted state. The ordered concatenation of all communicated (sent and received) messages by $\prod^t$ forms the session identification of $\prod^t$ for the current session.

Partnering. Two instances $\prod^{t_1}$ and $\prod^{t_2}$ are called partnered if the following three conditions are fulfilled simultaneously: (i) both $\prod^{t_1}$ and $\prod^{t_2}$ are in accepted state; (ii) both $\prod^{t_1}$ and $\prod^{t_2}$ authenticate each other mutually, and the identical session identification is shared; and (iii) $\prod^{t_1}$ and $\prod^{t_2}$ are mutual partners of each other.

Freshness. If the session key SK between U_i and SD_k has not revealed to an adversary $\mathcal{A}$ using the *Reveal*($\prod^t$) query given below, the instance $\prod_{U_i}^u$ or $\prod_{SD_k}^t$ is fresh.

Adversary. As described in Section 1.2, it is assumed that an adversary $\mathcal{A}$ has fully control over all the communications in smart home environment. In the random oracle model, $\mathcal{A}$ can operate the simulator and execute some queries to break the security of authentication messages and session keys. These queries are as follows:

Execute($\prod^u, \prod^v, \prod^t$): $\mathcal{A}$ can execute this query to simulate the entire authentication process, and the messages exchanged among the participants U_i, GWN and SD_k can be obtained.

Send($\prod^t, m$): This query means that $\mathcal{A}$ can send a message m and launch an active attack on a participating instance $\prod^t$. If m is appropriate and $\prod^t$ has no problem to receive it, according to $\mathcal{P}$, the simulator will give an answer which $\prod^t$ should produce. Otherwise, the simulator ignores the query.

Reveal($\prod^t$): This query means that the current session key SK generated by $\prod^t$ (and its partner) is revealed to an adversary $\mathcal{A}$.

CorruptMobileDevice($\prod_{U_i}^u$): $\mathcal{A}$ can run this query to acquire all sensitive data stored in the mobile device of the user.

CorruptSmartDevice($\prod_{SD_k}^t$): This query means that $\mathcal{A}$ can acquire the sensitive values stored in the smart device.

Test($\prod^t$): This query models the semantic security of the session key, in which the indistinguishability in the Real-Or-Random (ROR) model (Abdalla et al., 2005) is taking into consideration. $\mathcal{A}$ runs this query to do a challenge. Here $\prod$ may be the U_i or SD_k. The query begins with the tossing of an unbiased coin b, and only $\mathcal{A}$ knows the result which is used to decide the output of the *Test* query. If *Test*($\prod^t$) does not reach *accept*, the result $\perp$ (null) appears. Otherwise, *Test*($\prod^t$) returns the real session key SK if $b = 1$. On the contrary, $\mathcal{A}$ gets a random string which has the same length with the real session key if $b = 0$;

Semantic security of session key. As can be seen from the requirements of the ROR model (Abdalla et al., 2005), the adversary $\mathcal{A}$ needs to distinguish between the real session key of an instance and a random number. In particular, $\mathcal{A}$ may run several *Test* queries to either $\prod_{U_i}^u$ or $\prod_{SD_k}^t$, and the result of these queries must be consistent with the random bit b. At the end of the experiment, a guessed bit b^* is returned, and $\mathcal{A}$ wins the game if the condition $b = b^*$ is met. Let WIN denotes an event that $\mathcal{A}$ wins the game, let $\mathcal{P}$ be the proposed authenticated key agreement (AKE) scheme, and let $Adv_{\mathcal{P}}^{AKE}$ denotes the advantage of $\mathcal{A}$ in breaking the semantic secu-

rity of $\mathcal{P}$. Then, $\mathcal{P}$ against deriving the session key is given by $Adv_{\mathcal{P}}^{AKE} = |2Pr[WIN]-1|$. Therefore, $\mathcal{P}$ is secure in the ROR sense if $Adv_{\mathcal{P}}^{AKE} \leq \theta$, where $\theta > 0$ is a sufficiently small number.

Random oracle. All the participants in the proposed scheme and the adversary $\mathcal{A}$ will have access to a collision-resistant one-way hash function $h(.)$, which is further modeled as the *Hash* oracle.

4.1.2. Procedure of formal proof

Theorem 1. *Let $\mathcal{P}$ be the the proposed authentication scheme stated in Section 3. Let $\mathcal{A}$ be an adversary against the proposed scheme $\mathcal{P}$ in polynomial time t in the random oracle. Let D be an uniformly distributed password dictionary. The advantage of $\mathcal{A}$ in breaking semantic security of the proposed scheme $\mathcal{P}$ is estimated as:*

$$Adv_{\mathcal{P}}^{AKE} \leqslant \frac{q_{hash}^2}{|Hash|} + \frac{2q_{send}}{|D|} + 2Adv^{ECDLP}(t) \tag{1}$$

where q_{hash}, $|Hash|$, q_{send}, $|D|$ and $Adv^{ECDLP}(t)$ denote the number of hash queries, the range space of the one-way hash function, the number of send queries, the size of D, and the advantage of $\mathcal{A}$ in breaking the *ECDLP* problem, respectively.

Proof. Five different games, say GM_i ($i = 0, 1, 2, 3, 4$), are shown to describe the whole process. Let WIN_i denote an event where $\mathcal{A}$ guesses the bit b in the game GM_i and then wins that game. □

Game GM_0: This game simulates the real attack under random oracles environment. The bit b is chosen at the beginning of GM_0. Hence, it follows that:

$$Adv_{\mathcal{P}}^{AKE} = |2Pr[WIN_0] - 1| \tag{2}$$

Game GM_1: This game simulates the adversary's eavesdropping attacks by querying *Execute*$(\prod^u, \prod^v, \prod^t)$ oracle. At the end of this game, the adversary $\mathcal{A}$ queries *Test* oracle to determine whether it is the actual session key SK or a random value. The session key $SK = h(ID_i||GID_j||SID_k||R_1||R_2||R_3)$ contains U_i's contribution ID_i, R_1, and GWN's contribution GID_j, R_2, and SD_k's contribution SID_k, R_3. Thus, the adversary cannot compute SK from the transcripts because these sensitive values are unknown to him/her. Therefore, the chance of winning the game GM_1 for $\mathcal{A}$ is not increased by eavesdropping attack. Hence, we have

$$Pr[WIN_1] = Pr[WIN_0] \tag{3}$$

Game GM_2: On the basis of GM_1, we add the simulations of the *Send* and the *Hash* oracles, and it is called GM_2. This game models an active attack in which the adversary $\mathcal{A}$ tries to fool a participant to accept a modified message. In this game, $\mathcal{A}$ queries the *Hash* oracle repeatedly to find collisions. Since all the exchanged messages $\{DID_i, A_4, M_1, V_1\}$, $\{M_2, V_2\}$, $\{M_3, V_3\}$ and $\{M_4, V_4\}$ contain the identity of the participant and random nonce, there is no collision when the *Send* oracle is queried by $\mathcal{A}$. Using the results from the birthday paradox, we have

$$|Pr[WIN_2] - Pr[WIN_1]| \leqslant \frac{q_{hash}^2}{2|Hash|} \tag{4}$$

Game GM_3: The difference between GM_3 and GM_2 is that we add the simulations of the *CorruptMobileDevice*$(\prod_{U_i}^u)$ oracle and model the mobile device lost attack. Using the dictionary attack, the adversary $\mathcal{A}$ tries to acquire the user's password PW_i from the extracted information in the mobile device. It is also assumed that the number of wrong password inputs should be limited by the system. Thus, we have the following result,

$$|Pr[WIN_3] - Pr[WIN_2]| \leqslant \frac{q_{send}}{|D|} \tag{5}$$

Game GM_4: Game GM_4 is a modification of GM_3, and it is the last game. This game models the attack wherein the adversary $\mathcal{A}$ has compromised the smart device SD_k by simulating the *CorruptSmartDevice*$(\prod_{SD_k}^t)$ oracle. In this game, $\mathcal{A}$ can acquire the sensitive information $\{SID_k, K_{GS}\}$ stored in the smart device SD_k. In addition, $\mathcal{A}$ can eavesdrop all the exchanged messages $\{DID_i, A_4, M_1, V_1\}$, $\{M_2, V_2\}$, $\{M_3, V_3\}$ and $\{M_4, V_4\}$. However, $\mathcal{A}$ can not decrypt M_1 and M_4 because the necessary information K_{GU} is unknown to him/her. In order to obtain K_{GU}, $\mathcal{A}$ has to solve the problem of *ECDLP*. Let $Adv^{ECDLP}(t)$ be the advantage of $\mathcal{A}$ in breaking the *ECDLP* problem. Thus, we have,

$$|Pr[WIN_4] - Pr[WIN_3]| \leqslant Adv^{ECDLP}(t) \tag{6}$$

In GM_4, all the random oracles are simulated, and $\mathcal{A}$ has no advantage in guessing the bit b. This leads to the following:

$$Pr[WIN_4] = \frac{1}{2} \tag{7}$$

From Eqs. (2) and (3), we have,

$$\frac{1}{2}Adv_{\mathcal{P}}^{AKE} = |Pr[WIN_0] - \frac{1}{2}| = |Pr[WIN_1] - \frac{1}{2}| \tag{8}$$

Using Eqs. (3)–(6) and the triangular inequality, we have,

$$\begin{aligned}
&|Pr[WIN_1] - Pr[WIN_4]| \\
&= |Pr[WIN_1] - Pr[WIN_2] + Pr[WIN_2] - Pr[WIN_4]| \\
&= |Pr[WIN_1] - Pr[WIN_2] + Pr[WIN_2] - Pr[WIN_3] \\
&\quad + Pr[WIN_3] - Pr[WIN_4]| \\
&\leqslant |Pr[WIN_1] - Pr[WIN_2]| + |Pr[WIN_2] - Pr[WIN_3]| \\
&\quad + |Pr[WIN_3] - Pr[WIN_4]| \\
&\leqslant \frac{q_{hash}^2}{2|Hash|} + \frac{q_{send}}{|D|} + Adv^{ECDLP}(t)
\end{aligned} \tag{9}$$

Using Eqs. (7) and (9), we have

$$|Pr[WIN_1] - \frac{1}{2}| \leqslant \frac{q_{hash}^2}{2|Hash|} + \frac{q_{send}}{|D|} + Adv^{ECDLP}(t) \tag{10}$$

Using Eqs. (8) and (10), we have the required result,

$$Adv_{\mathcal{P}}^{AKE} \leqslant \frac{q_{hash}^2}{|Hash|} + \frac{2q_{send}}{|D|} + 2Adv^{ECDLP}(t) \tag{11}$$

This result means $\mathcal{A}$ has no extra advantage to win the game and the theorem is finally deduced. Therefore, the proposed scheme is secure under random oracle model.

Table 2 – Notations in BAN logic.

Notation	Implications
$P \lhd X$	Principal P sees message X
$P\mid\equiv X$	Principal P believes message X
$P\mid\Rightarrow X$	Principal P has jurisdiction over message X
$P\mid\sim X$	Principal P once said message X
$\#(X)$	Message X is fresh
(X, Y)	Message X or Y is one part of message (X, Y)
$<X>_K$	Message X is encrypted with the key K
$(X)_K$	Message X is hashed with the key K
$P \overset{K}{\longleftrightarrow} Q$	Principal P and principal Q communicate with the shared key K

4.2. *Formal security analysis using BAN logic*

BAN logic is a set of rules for defining and analyzing authentication protocols, which is widely-used in many works, such as (Baruah and Dhal, 2018; Challa et al., 2017; Hsieh and Leu, 2012). In BAN logic, the exchanged information is first assumed to be happen on channels which are vulnerable to tampering and public monitoring. After that, the postulates and definitions, such as the axiomatic systems, are used to analyze authentication protocols. Then, the trustworthiness and security of the exchanged information is confirmed with the help of the BAN logic. Therefore, a typical BAN logic sequence includes three steps, i.e. verification of message origin, verification of message freshness and verification of the origin's trustworthiness. For convenience, all the notations used in the BAN logic are given in Table 2:

Basic rules of BAN logic are as follows:

Message-meaning rule: $\frac{P\mid\equiv P\overset{K}{\longleftrightarrow}Q, P\lhd X_K}{P\mid\equiv Q\mid\sim X}$

Nonce-verification rule: $\frac{P\mid\equiv\#(X), P\mid\equiv Q\mid\sim X}{P\mid\equiv Q\mid\equiv X}$

Jurisdiction rule: $\frac{P\mid\equiv Q\mid\Rightarrow X, P\mid\equiv Q\mid\equiv X}{P\mid\equiv X}$

Freshness-conjuncatenation rule: $\frac{P\mid\equiv\#(X)}{P\mid\equiv\#(X,Y)}$

Belief rule: $\frac{P\mid\equiv(X), P\mid\equiv(Y)}{P\mid\equiv(X,Y)}$

Session keys rule: $\frac{P\mid\equiv\#(X), P\mid\equiv Q\mid\equiv X}{P\mid\equiv P\overset{K}{\longleftrightarrow}Q}$

The proposed scheme needs to satisfy the following eight goals:

Goal1: $U_i \mid\equiv (U_i \overset{SK}{\longleftrightarrow} SD_k)$

Goal2: $U_i \mid\equiv SD_k \mid\equiv (U_i \overset{SK}{\longleftrightarrow} SD_k)$

Goal3: $SD_k \mid\equiv (U_i \overset{SK}{\longleftrightarrow} SD_k)$

Goal4: $SD_k \mid\equiv U_i \mid\equiv (U_i \overset{SK}{\longleftrightarrow} SD_k)$

Goal5: $GWN \mid\equiv (GWN \overset{SK}{\longleftrightarrow} U_i)$

Goal6: $GWN \mid\equiv U_i \mid\equiv (GWN \overset{SK}{\longleftrightarrow} U_i)$

Goal7: $GWN \mid\equiv (GWN \overset{SK}{\longleftrightarrow} SD_k)$

Goal8: $GWN \mid\equiv SD_k \mid\equiv (GWN \overset{SK}{\longleftrightarrow} SD_k)$

First, the messages exchanged in the proposed scheme can be transformed into idealized forms as follows.

Msg1: $U_i \rightarrow GWN$: $\{DID_i, A_4, M_1, V_1\}$:
$\{< ID_i >_{w\cdot x}, w\cdot P, < R_1||SID_k >_{h(ID_i||K)}, (ID_i||R_1)_{h(ID_i||K)}\}$

Msg2: $GWN \rightarrow SD_k$: $\{M_2, V_2\}$:
$\{< ID_i, GID_j, R_1, R_2 >_{h(SID_k||K)}, (ID_i, GID_j, R_1, R_2)_{h(SID_k||K)}\}$

Msg3: $SD_k \rightarrow GWN$: $\{M_3, V_3\}$:
$\{< R_3 >_{h(SID_k||K)}, (R_3)_{h(SID_k||K).SK}\}$

Msg4: $GWN \rightarrow U_i$: $\{M_4, V_4\}$:
$\{< GID_j, R_2, R_3 >_{h(ID_i||K)}, (R_2, R_3)_{h(ID_i||K).SK}\}$

Second, some initial assumptions about the proposed scheme are listed below:

A1: $GWN \mid\equiv \#(R_1)$

A2: $SD_k \mid\equiv \#(R_2)$

A3: $GWN \mid\equiv \#(R_3)$

A4: $U_i \mid\equiv U_i \overset{xw\cdot P}{\longleftrightarrow} GWN$

A5: $GWN \mid\equiv GWN \overset{wx\cdot P}{\longleftrightarrow} U_i$

A6: $GWN \mid\equiv GWN \overset{h(SID_k||K)}{\longleftrightarrow} SD_k$

A7: $SD_k \mid\equiv SD_k \overset{h(SID_k||K)}{\longleftrightarrow} GWN$

A8: $U_i\mid\equiv SD_k\mid\Rightarrow\{R_3, SID_k, SK\}$

A9: $U_i\mid\equiv GWN\mid\Rightarrow\{R_2, GID_j, SK, wx\cdot P\}$

A10: $GWN\mid\equiv U_i\mid\Rightarrow\{R_1, ID_i, SK, xw\cdot P\}$

A11: $GWN\mid\equiv SD_k\mid\Rightarrow\{R_3, SID_k, SK\}$

A12: $SD_k\mid\equiv U_i\mid\Rightarrow\{R_1, U_i, SK\}$

A13: $SD_k\mid\equiv GWN\mid\Rightarrow\{R_2, GID_j, SK\}$

Third, based on the BAN logic rules and assumptions, the main proofs are performed as follows:

According to the Msg1, we get:

S1: $GWN \lhd \{< ID_i >_{w\cdot x}, w\cdot P, < R_1||SID_k >_{h(ID_i||K)}, (ID_i||R_1)_{h(ID_i||K)}\}$

Based on Assumption A5, S1 and message-meaning rule, we have:

S2: $GWN\mid\equiv U_i\mid\sim$
$\{< ID_i >_{w\cdot x}, w\cdot P, < R_1||SID_k >_{h(ID_i||K)}, (ID_i||R_1)_{h(ID_i||K)}\}$

From A1 and freshness-conjuncatenation rule, we get:

S3: $GWN \mid\equiv \#\{< ID_i >_{w\cdot x}, w\cdot P, < R_1||SID_k >_{h(ID_i||K)}, (ID_i||R_1)_{h(ID_i||K)}\}$

From S3, S2 and nonce-verification rule, we get:

S4: $GWN\mid\equiv U_i\mid\equiv$
$\{< ID_i >_{w\cdot x}, w\cdot P, < R_1||SID_k >_{h(ID_i||K)}, (ID_i||R_1)_{h(ID_i||K)}\}$

According to the Msg2, we get:

S5: $SD_k \lhd \{< ID_i, GID_j, R_1, R_2 >_{h(SID_k||K)}, (ID_i, GID_j, R_1, R_2)_{h(SID_k||K)}\}$

From A7, S5 and message-meaning rule, we have:

S6: $SD_k\mid\equiv GWN\mid\sim$
$\{< ID_i, GID_j, R_1, R_2 >_{h(SID_k||K)}, (ID_i, GID_j, R_1, R_2)_{h(SID_k||K)}\}$

From A2 and freshness-conjuncatenation rule, we get:

S7: $SD_k \mid\equiv \#\{< ID_i, GID_j, R_1, R_2 >_{h(SID_k||K)}, (ID_i, GID_j, R_1, R_2)_{h(SID_k||K)}\}$

From S6, S7 and nonce-verification rule, we get:

S8: $SD_k\mid\equiv GWN\mid\equiv\{< ID_i, GID_j, R_1, R_2 >_{h(SID_k||K)}, (ID_i, GID_j, R_1, R_2)_{h(SID_k||K)}\}$

According to the Msg3, we get:

S9: $GWN \lhd \{< R_3 >_{h(SID_k||K)}, (R_3)_{h(SID_k||K).SK}\}$

From A6, S9 and message-meaning rule, we have:

S10: $GWN \mid\equiv SD_k \mid\sim \{< R_3 >_{h(SID_k||K)}, (R_3)_{h(SID_k||K).SK}\}$

From A3 and freshness-conjuncatenation rule, we get:

S11: $GWN \mid\equiv \#\{< R_3 >_{h(SID_k||K)}, (R_3)_{h(SID_k||K).SK}\}$

From S10, S11 and nonce-verification rule, we get:

S12: $GWN \mid\equiv SD_k \mid\equiv \{< R_3 >_{h(SID_k||K)}, (R_3)_{h(SID_k||K).SK}\}$

According to the Msg4, we get:

S13: $U_i \lhd \{< GID_j, R_2, R_3 >_{h(ID_i||K)}, (R_2, R_3)_{h(ID_i||K).SK}\}$

From A4, S13 and message-meaning rule, we have:

S14: $U_i \mid\equiv GWN \mid\sim \{< GID_j, R_2, R_3 >_{h(ID_i||K)}, (R_2, R_3)_{h(ID_i||K).SK}\}$

From A1, A2, A3 and freshness-conjuncatenation rule, we get:

S15: $U_i \mid\equiv \#\{< GID_j, R_2, R_3 >_{h(ID_i||K)}, (R_2, R_3)_{h(ID_i||K),SK}\}$

From S14, S15 and nonce-verification rule, we get:

S16: $U_i \mid\equiv GWN \mid\equiv \{< GID_j, R_2, R_3 >_{h(ID_i||K)}, (R_2, R_3)_{h(ID_i||K),SK}\}$

From S4, A5, A10 and jurisdiction rule, we get:

S17: $GWN \mid\equiv \{< ID_i >_{w \cdot X}, w \cdot P, < R_1||SID_k >_{h(ID_i||K)}, (ID_i||R_1)_{h(ID_i||K)}\}$

From S3, S4, S17 and session keys rule, we get:

S18: $GWN \mid\equiv U_i \mid\equiv (GWN \overset{SK}{\longleftrightarrow} U_i)$ (Goal6)

From S18, A10 and jurisdiction rule, we get:

S19: $GWN \mid\equiv (GWN \overset{SK}{\longleftrightarrow} U_i)$ (Goal5)

From S12, A11 and jurisdiction rule, we get:

S20: $GWN \mid\equiv \{< R_3 >_{h(SID_k||K)}, (R_3)_{h(SID_k||K),SK}\}$

From S11, S12, S20 and session keys rule, we get:

S21: $GWN \mid\equiv SD_k \mid\equiv (GWN \overset{SK}{\longleftrightarrow} SD_k)$ (Goal8)

From S21, A11 and jurisdiction rule, we get:

S22: $GWN \mid\equiv (GWN \overset{SK}{\longleftrightarrow} SD_k)$ (Goal7)

From S8, A13 and jurisdiction rule, we get:

S23: $SD_k \mid\equiv \{< ID_i, GID_j, R_1, R_2 >_{h(SID_k||K)}, (ID_i, GID_j, R_1, R_2)_{h(SID_k||K)}\}$

From S7, S8, S23 and session keys rule, we get:

S24: $SD_k \mid\equiv GWN \mid\equiv (GWN \overset{SK}{\longleftrightarrow} SD_k)$

From S24, A13 and jurisdiction rule, we get:

S25: $SD_k \mid\equiv (GWN \overset{SK}{\longleftrightarrow} SD_k)$

From S16, A9 and jurisdiction rule, we get:

S26: $U_i \mid\equiv \{< GID_j, R_2, R_3 >_{h(ID_i||K)}, (R_2, R_3)_{h(ID_i||K),SK}\}$

From S15, S16, S26 and session keys rule, we get:

S27: $U_i \mid\equiv GWN \mid\equiv (U_i \overset{SK}{\longleftrightarrow} GWN)$

From S27, A9 and jurisdiction rule, we get:

S28: $U_i \mid\equiv (U_i \overset{SK}{\longleftrightarrow} GWN)$

From S18 and S24, we get:

S29: $U_i \mid\equiv SD_k \mid\equiv (U_i \overset{SK}{\longleftrightarrow} SD_k)$ (Goal2)

From S21 and S27, we get:

S30: $SD_k \mid\equiv U_i \mid\equiv (U_i \overset{SK}{\longleftrightarrow} SD_k)$ (Goal4)

From S29, A9 and jurisdiction rule, we get:

S31: $U_i \mid\equiv (U_i \overset{SK}{\longleftrightarrow} SD_k)$ (Goal1)

From S30, A12 and jurisdiction rule, we get:

S32: $SD_k \mid\equiv (U_i \overset{SK}{\longleftrightarrow} SD_k)$ (Goal3)

Therefore, the above BAN logic analysis formally proves that the proposed scheme achieves mutual authentication successfully, and the session key SK is established between the user and the smart device with the assistance of GWN.

4.3. *Formal security validation using ProVerif*

ProVerif (Blanchet, 2001) is an automatic cryptographic protocol verifier in the formal model (so called Dolev-Yao model), which is widely applied in many works, such as Wu et al. (2018), Wu et al. (2016) and Xiong et al. (2017). ProVerif supports many different cryptographic primitives, including hash functions, symmetric and asymmetric cryptography, Diffie–Hellman key agreements, digital signatures, etc. With the help of ProVerif, the security properties of authentication protocol, such as mutual authentication, secrecy, equivalences between processes, can be checked successfully. In this section, we conduct a formal security validation using the tool Proverif. In order to analyze the security of the proposed scheme, two public channels ch1, ch2 are defined, where ch1 represents the public channel between the user and GWN, ch2 expresses the public channel between GWN and the smart device. After that, the basic types of variables are defined, and the cryptographic functions are modelled. Moreover, four values svalueA, svalueB, svalueC, svalueD are used to verify the secrecy of session key SK. In order to verify mutual authentication of the proposed scheme, eight events are declared as follows. event UGbegin(entity), event UGend(entity), event GUbegin(entity), event GUend(entity), event GSbegin(entity), event GSend(entity), event SGbegin(entity), event SGend(entity).

Then, the processes of the user, GWN and the smart device are demonstrated, respectively. Finally, we model the entire program. The ProVerif scripts associated with the analysis in this paper are available online: https://github.com/smx12345/code/blob/master/home.pv, and the simulation results using the version 1.96 of ProVerif are demonstrated in Fig. 4.

The results demonstrate that the proposed scheme can fulfill the secrecy of session key and achieve mutual authentication successfully.

4.4. *Further security analysis of the proposed scheme*

In this section, the security and functional features of the proposed scheme are discussed.

4.4.1. *Mutual authentication*

In the proposed scheme, the user U_i and the smart device SD_k authenticate each other with the help of the GWN. In particular, U_i and GWN authenticate each other by checking V_1 and V_4, respectively. Similarly, GWN and SD_k authenticate each other by checking V_2 and V_3, respectively. Therefore, the proposed scheme achieves mutual authentication successfully.

4.4.2. *Session key agreement*

In the proposed scheme, the session key $SK = h(ID_i||GID_j||SID_k||R_1||R_2||R_3)$ is established between the user U_i and the smart device SD_k, which is used for future communications. The session key SK contains U_i's contribution ID_i, R_1, and GWN's contribution GID_j, R_2, and SD_k's contribution SID_k, R_3. Any third party can not predetermine the session key. Therefore, the proposed scheme provides session key agreement.

4.4.3. *User anonymity and untraceability*

User anonymity is an important security feature of authentication scheme, which mainly comprises two meanings. The first meaning is user identity-protection which means the real identity of the user cannot be figured out by the adversary, and the second meaning is user untraceability which guarantees the adversary neither determining who the user is nor telling apart whether two sessions are executed by the same user (Wang and Wang, 2014a). In the proposed scheme, an attacker $\mathscr{A}$ cannot get the user's identity ID_i from the communication messages directly since the plaintext of user's real identity ID_i does not contain in any messages. On the contrary, the identity ID_i is implied in messages DID_i, M_1, V_1, M_2 and V_2. Without knowing GWN's secret keys x and K, $\mathscr{A}$ cannot retrieve the user's real identity ID_i from the communication messages. In addition, the user generates the random numbers w and R_1 randomly in each session, and the transmitted

```
Completing equations...
Completing equations...
-- Query inj-event(UGend(t)) ==> inj-event(UGbegin(t))
Completing...
200 rules inserted. The rule base contains 196 rules. 10 rules in the queue.
Starting query inj-event(UGend(t)) ==> inj-event(UGbegin(t))
RESULT inj-event(UGend(t)) ==> inj-event(UGbegin(t)) is true.
-- Query inj-event(GUend(t_63)) ==> inj-event(GUbegin(t_63))
Completing...
200 rules inserted. The rule base contains 200 rules. 23 rules in the queue.
Starting query inj-event(GUend(t_63)) ==> inj-event(GUbegin(t_63))
RESULT inj-event(GUend(t_63)) ==> inj-event(GUbegin(t_63)) is true.
-- Query inj-event(GSend(t_64)) ==> inj-event(GSbegin(t_64))
Completing...
200 rules inserted. The rule base contains 200 rules. 23 rules in the queue.
Starting query inj-event(GSend(t_64)) ==> inj-event(GSbegin(t_64))
RESULT inj-event(GSend(t_64)) ==> inj-event(GSbegin(t_64)) is true.
-- Query inj-event(SGend(t_65)) ==> inj-event(SGbegin(t_65))
Completing...
200 rules inserted. The rule base contains 194 rules. 10 rules in the queue.
Starting query inj-event(SGend(t_65)) ==> inj-event(SGbegin(t_65))
RESULT inj-event(SGend(t_65)) ==> inj-event(SGbegin(t_65)) is true.
-- Query not attacker(svalueA[]); not attacker(svalueB[]); not attacker(svalueC[]); not
attacker(svalueD[])
Completing...
200 rules inserted. The rule base contains 192 rules. 9 rules in the queue.
Starting query not attacker(svalueA[])
RESULT not attacker(svalueA[]) is true.
Starting query not attacker(svalueB[])
RESULT not attacker(svalueB[]) is true.
Starting query not attacker(svalueC[])
RESULT not attacker(svalueC[]) is true.
Starting query not attacker(svalueD[])
RESULT not attacker(svalueD[]) is true.
```

Fig. 4 – The simulation results for the ProVerif.

messages in current session are also different from other sessions. Therefore, the proposed scheme can not only protect user's real identity, but also achieve user untraceability.

4.4.4. *Resist mobile device loss attack*

Research shows that the secret values stored in smart card or mobile device can be retrieved by using side-channel attacks (Spreitzer et al., 2017), such as power analysis attack (Kocher et al., 1999; Messerges et al., 2002), electromagnetic analysis attack (Mulder et al., 2005) and fault analysis attacks (Alkhoraidly et al., 2012; Barenghi et al., 2009). Therefore, the mobile device loss attack should be taken into consideration when design an authentication scheme using mobile device. In the proposed scheme, the mobile device of the user contains the secret parameters $\{A_1, A_2, A_3, TEMP\}$, where $A_1 = K_{GU} \oplus HPW_i = h(ID_i||K) \oplus h(PW_i||a)$, $A_2 = a \oplus h(ID_i||PW_i)$, $A_3 = h(ID_i||HPW_i) = h(ID_i||h(PW_i||a))$. Suppose that an attacker $\mathscr{A}$ picks up or steals the mobile device and obtains the stored secret values $\{A_1, A_2, A_3, TEMP\}$, $\mathscr{A}$ cannot get the correct identity and password without knowing the U_i's secret random integer a and GWN's secret key K, and then $\mathscr{A}$ cannot impersonate as the user. Therefore, the proposed scheme is robust even if the mobile device is lost or stolen.

4.4.5. *Fault analysis attack*

Fault analysis attack is a powerful tool to extract the secret information partially or fully by exploiting faults occurred in the implementation of the cryptosystem. Fault analysis attack targets the implementation weaknesses rather than the mathematical structure, and it is mainly used for attacking cryptosystem, such as Elliptic Curve Cryptosystems, Pairing-Based Cryptography and *RSA* Cryptosystem. In Section 4.4.4, we demonstrate that the proposed scheme is robust even if the mobile device is lost or stolen and the stored secret values are retrieved using fault analysis attacks (Alkhoraidly et al., 2012; Barenghi et al., 2009). Now, we discuss the fault analysis attack during the implementation of the scheme. In the proposed scheme, even if the random numbers w and R_1 generated in the process of authentication are obtained by the attacker $\mathscr{A}$ using fault analysis attacks, and $\mathscr{A}$ further computes the session key $SK = h(ID_i||GID_j||SID_k||R_1||R_2||R_3)$. Since the random numbers R_1, R_2, R_3 are different for each session, the compromise of a session key in one session has no help to compromise previous established and future session keys. Therefore, the proposed scheme is robust even if the fault analysis attack is considered.

4.4.6. *Resist replay attack*

In the proposed scheme, the random number method is adopted to resist replay attack. In each session, random numbers R_1, R_2 and R_3 are generated by the user U_i, GWN and the smart device SD_k, respectively. These random numbers are used to ensure the freshness and independence of exchanged messages. Therefore, the proposed scheme is secure from replay attack.

4.4.7. *Resist privileged insider attack*

When U_i registers to RA as a valid user in the proposed scheme, U_i sends the registration request message $\{ID_i, HPW_i\}$ to RA. A malicious privileged insider attacker cannot obtain

U_i's password PW_i from HPW_i since it is shielded by the random number a and protected by the one-way hash function. Therefore, the proposed scheme can withstand the privileged insider attack.

4.4.8. *Quickly detection for unauthorized login*

Detection mechanism for unauthorized login allows the mobile device to quickly detect and reject unauthorized login when the user inputs wrong information, and it saves unnecessary communication and computation cost in the beginning of login and authentication phase. In the proposed scheme, the parameter A_3 stored in the mobile device is used to verify the correctness of user information, where $A_3^* = h(ID_i||HPW_i^*)$, $HPW_i^* = h(PW_i||a^*)$, $a^* = A_2 \oplus h(ID_i||PW_i)$. If an attacker inputs wrong identity ID_i and password PW_i, the values A_3^* and A_3 are not equal. Then, the mobile device rejects the U_i's login request. Therefore, the proposed scheme provides quickly detection for unauthorized login.

4.4.9. *Resist de-synchronization attack*

In the proposed scheme, the same secret data is not stored in the endpoint entities. In addition, the endpoint entities do not need to update any information when a session is completed. Therefore, the de-synchronization attack is impossible.

4.4.10. *Resist impersonation attacks*

In the proposed scheme, if an attacker $\mathscr{A}$ wants to impersonate the user, he/she must knows the user's identity ID_i and password PW_i. However, as discussed in resisting mobile device loss attack, $\mathscr{A}$ can not get the correct identity and password even if he/she obtains the user's mobile device. Thus, the proposed scheme is secure from user impersonation attack. Besides, the secret value x and the secret key K are held by GWN only, $\mathscr{A}$ can not generate valid communication messages without them. Therefore, the proposed scheme is secure from GWN impersonation attack.

4.4.11. *Resist man-in-the-middle attack*

According to the analysis in Sections 4.2, 4.3 and 4.4.1, the proposed scheme can provide mutual authentication successfully. Besides, the transmitted messages are protected by the secret values K_{GU} and K_{GS}, and anyone without them cannot forge legal authentication messages. Therefore, the proposed scheme can resist the man-in-the-middle attack.

4.4.12. *Forward secrecy*

In the proposed scheme, the established session key SK includes U_i's contribution ID_i, R_1, and GWN's contribution GID_j, R_2, and SD_k's contribution SID_k, R_3. The random numbers R_1, R_2, R_3 are randomly generated for each session. So if the long-term keys are compromised by an attacker $\mathscr{A}$, it can not affect the confidentiality of past communications. Therefore, forward secrecy is provided in the proposed scheme.

4.5. *Security comparisons*

The comparison results of security features among the proposed scheme and four prior related schemes (Han et al., 2013; Kumar et al., 2015; Li, 2013; Wazid et al., 2017) are shown in Table 3. From Table 3, we can see that the schemes in Kumar et al. (2015), Li (2013) and Han et al. (2013) lacks the mutual authentication between user and GWN as well as between user and smart device. Besides, the anonymity and untraceability properties are also not provided in Kumar et al.'s scheme, and it may face the clock synchronization problem because the time stamp has been adopted to resist the replay attack. Moreover, Wazid et al.'s (2017) scheme suffers from de-synchronization attack, and forward security is also not provided. In their scheme, GWN should keep a verification table for authentication, and it is disastrous if the verification table is stolen by an adversary. Similar to Kumar et al.'s (2015) scheme, their scheme may also face the clock synchronization problem. Furthermore, Li's (2013) scheme was not scalable since the management of a large number of keys and certificates is required, and the scheme in Han et al. (2013) is unrealistic because it requires the manufacturers to keep always online. Compared with the most representative related schemes in recent years, the proposed scheme can resist against various kinds of known attacks and provide the desirable functional features.

5. Performance comparison

In this section, we first compare the computational costs of the proposed scheme with four prior related schemes, i.e., Kumar et al.'s (2015) scheme, Wazid et al.'s (2017) scheme, Li's (2013) scheme and Han et al.'s (2013) scheme. Then, the comparisons of the communication overheads and communication energy costs are presented, respectively.

5.1. *Computation cost*

In the performance analysis, the computation cost of a scheme is evaluated according to all the computations required in the scheme (Hsieh and Leu, 2012). For the convenience of computation analysis, we define T_{ED}, T_{exp}, T_{fe}, T_{mac}, T_{hmac} and T_h as the time cost of symmetric encryption/decryption, an ECC point multiplication, fuzzy extractor generation/reproduction procedure, message authentication code (MAC) and hashed MAC, and a hash operation, respectively. According to the simulation results of Wu et al. (2016), T_{ED}, T_{exp} and T_h are 0.0215 ms, 0.4276 ms and 0.0052 ms, respectively. The simulation is achieved on an Intel(R) Core TM i7-4710HQ 2.50GHz machine with the 64-bit Windows 8 operating system and 8 GB memory. Moreover, the fuzzy extractor in Wazid et al.'s (2017) scheme can be constructed from universal hash functions or error-correcting codes that require only lightweight operations (Dodis et al., 2004), so it is assumed that the time for executing a fuzzy extractor is the same as an ECC point multiplication at most (He et al., 2014). It is further assumed that T_{mac} and T_{hmac} are equal to T_h approximately. Table 4 shows the comparison results of computational costs between the proposed scheme and other related schemes (Han et al., 2013; Kumar et al., 2015; Li, 2013; Wazid et al., 2017).

As shown in Table 4, the computation cost of the proposed scheme is slightly higher than Kumar et al.'s (2015) scheme, Wazid et al.'s (2017) scheme and Han et al.'s (2013) scheme. However, as is demonstrated in Section 4.5, the proposed

Table 3 – Security attributes comparison.

Security attributes	Kumar et al. (2015)	Wazid et al. (2017)	Li (2013)	Han et al. (2013)	Ours
Suitable for realistic environments	No	No	No	No	Yes
Mutual authentication	No	Yes	No	No	Yes
Session key agreement	Yes	Yes	Yes	Yes	Yes
User anonymity	No	Yes	Yes	Yes	Yes
Untraceability	No	Yes	Yes	Yes	Yes
Avoid of clock synchronization problem	No	No	Yes	Yes	Yes
No verification table	Yes	No	Yes	Yes	Yes
Forward security	Yes	No	Yes	Yes	Yes
De-synchronization attack	Yes	No	Yes	Yes	Yes
Unauthorized login detection	No	Yes	No	No	Yes
Mobile device loss attack	Yes	Yes	Yes	Yes	Yes
Privileged insider attack	Yes	Yes	Yes	Yes	Yes
Impersonation attack	Yes	Yes	Yes	Yes	Yes
Replay attack	Yes	Yes	Yes	Yes	Yes
Man-in-the-middle attack	Yes	Yes	Yes	Yes	Yes
Formal proof	No	Yes	No	No	Yes
Formal verification	Yes	Yes	Yes	No	Yes

Table 4 – Comparison of computational costs.

Authentication scheme	Total cost	Rough estimation
Kumar et al.'s (2015) scheme	$2T_{ED} + T_{mac} + T_{hmac} + 2T_h$	0.0638 ms
Wazid et al.'s (2017) scheme	$4T_{ED} + T_{fe} + 22T_h$	0.628 ms
Li's (2013) scheme	$4T_{exp} + 2T_{ED} + 2T_{mac} + 2T_h$	1.7742 ms
Han et al.'s (2013) scheme	$6T_{ED} + 12T_{mac} + 10T_h$	0.2434 ms
The proposed scheme	$3T_{exp} + 16T_h$	1.366 ms

Table 5 – Comparison of communication overheads.

Authentication scheme	Total messages	Total cost (Bits)
Kumar et al.'s (2015) scheme	3 Messages	1376
Wazid et al.'s (2017) scheme	4 Messages	2082
Li's (2013) scheme	4 Messages	1216
Han et al.'s (2013) scheme	6 Messages	2272
The proposed scheme	4 Messages	1728

scheme supports more functionality and security features. Therefore, from Tables 3 and 4, it can be concluded that the proposed scheme achieves a delicate balance between security and efficiency.

5.2. *Communication overhead*

Table 4 shows the comparison of communication overheads between the proposed scheme and four prior related schemes (Han et al., 2013; Kumar et al., 2015; Li, 2013; Wazid et al., 2017). In order to achieve a convincing comparison, we assume that the length of user's identity, user's pseudonym identity, user's password, sensor's identity, the time stamp, the secret key, the random number, the ECC point multiplication, the ciphertext block in symmetric encryption/decryption, the output of hash function and MAC are 128 bits, 128 bits, 128 bits, 128 bits, 32 bits, 160 bits, 160 bits, 320 bits, 256 bits, 160 bits, 160 bits, respectively. In the proposed scheme, the transmitted messages $\{DID_i, A_4, M_1, V_1\}$, $\{M_2, V_2\}$, $\{M_3, V_3\}$ and $\{M_4, V_4\}$ require (128+320+160+160) = 768 bits, (160+160) = 320 bits, (160+160) = 320 bits, (160+160) = 320 bits, respectively. Combining the above four values, the total communication overhead of the proposed scheme is 1728 bits. Similarly, the total communication overheads of Kumar et al.'s (2015) scheme, Wazid et al.'s (2017) scheme, Li's (2013) scheme and Han et al.'s (2013) scheme are 1376 bits, 2082 bits, 1216 bits, 2272 bits, respectively. Although there is a slightly advantage in the communication overhead of Kumar et al.'s (2015) scheme and Li's (2013) scheme, their scheme fails to provide mutual authentication between user and GWN as well as between user and smart device. Therefore, the proposed scheme is effective and more suitable for realistic environments.

5.3. *Energy consumption cost*

In this section, the consumption model used in Das et al. (2016) and Kumar et al. (2018) is adopted to compute the energy consumption cost. According to the literature (Shnayder et al., 2004), the energy costs of transmitting and receiving a bit are 4.602 and 2.34 mJ/bit, respectively. Table 6 shows the comparison of energy consumption cost between the proposed scheme and four prior related schemes (Han et al., 2013; Kumar et al., 2015; Li, 2013; Wazid et al., 2017). In the proposed scheme, the total transmission energy for all the entities is 7216 mJ. Similarly, the total transmission energy of Kumar et al.'s (2015) scheme, Wazid et al.'s (2017) scheme, Li's (2013) scheme and Han et al.'s (2013) scheme are 6774 mJ,

Table 6 – Comparison of energy consumption cost.

Authentication scheme	Total transmission energy (mJ)	Transmission energy for smart device (mJ)
Kumar et al.'s (2015) scheme	6774	2651
Wazid et al.'s (2017) scheme	10,907	2798
Li's (2013) scheme	4418	1473
Han et al.'s (2013) scheme	8689	2209
The proposed scheme	7216	1473

10907 mJ, 4418 mJ and 8689 mJ, respectively. From comparison in Table 6, it is noted that the total transmission energy of the proposed scheme is less than the schemes (Han et al., 2013; Wazid et al., 2017), and it is slightly higher than the schemes (Kumar et al., 2015; Li, 2013). However, the proposed scheme has the least transmission energy for the smart device. Therefore, compared with four prior related schemes (Han et al., 2013; Kumar et al., 2015; Li, 2013; Wazid et al., 2017), the proposed scheme is one of the most energy efficient schemes for resource constrained smart devices in smart home environment.

6. Conclusion

Security and privacy issues are major obstacles that hinder the large-scale applications of smart home. In previous research, there are almost no comprehensive authentication schemes suitable for smart home environment. As a step towards this direction, in this paper, we have presented a lightweight and secure two-factor anonymous authentication scheme using ECC. The proposed scheme allows a legal user mutually authenticate with the smart device with the help of *GWN*. At the end of successful mutual authentication, a symmetric session key *SK* is established between the user and the smart device for future secure communications. The security of the proposed scheme is proved by rigorous formal proof using random oracle model and broadly-accepted BAN logic. Moreover, the formal security verification using the widely accepted tool ProVerif demonstrate that the proposed scheme can fulfill the secrecy of session key and achieve mutual authentication successfully. Through the heuristic way, the security and functional features are discussed, and it has proven that the proposed scheme is robust to resist various of attacks and achieves some ideal features. Furthermore, we compared the proposed scheme with four representative related schemes in security and performance aspects, and the comparison results illustrate that the proposed scheme is secure and more suitable for smart home environment.

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Acknowledgments

The authors would like to thank the reviewers for their insightful comments and helpful suggestions.

REFERENCES

Abdalla M, Fouque PA, Pointcheval D. Password-based authenticated key exchange in the three-party setting, 153; 2005. p. 65–84. doi:10.1007/978-3-540-30580-4_6.

Alkhoraidly A, Dominguez-Oviedo A, Hasan M. Fault attacks on elliptic curve cryptosystems. Fault analysis in cryptography, 1. Springer Berlin Heidelberg; 2012. p. 137–55.

Barenghi A, Bertoni G, Parrinello E, Pelosi G. Low voltage fault attacks on the rsa cryptosystem, 1; 2009. p. 23–31. doi:10.1109/FDTC.2009.30.

Baruah B, Dhal S. A two-factor authentication scheme against FDM attack in IFTTT based smart home system. Comput Secur 2018;77:21–35. doi:10.1016/j.cose.2018.03.004.

Blanchet B. An efficient cryptographic protocol verifier based on prolog rules, 1; 2001. p. 82–96. doi:10.1109/CSFW.2001.930138.

Challa S, Das AK, Odelu V, Kumar N, Kumari S, Khan MK, Vasilakos A. An efficient ECC-based provably secure three-factor user authentication and key agreement protocol for wireless healthcare sensor networks. Comput Electr Eng 2017;PP. doi:10.1016/j.compeleceng.2017.08.003. 1–1

Chuang MC, Lee JF. Team: Trust-extended authentication mechanism for vehicular ad hoc networks, 8(3); 2011. p. 1758–61. doi:10.1109/CECNET.2011.5768376.

Das AK, Sutrala AK, Kumari S, Odelu V, Wazid M, Li X. An efficient multi-gateway-based three-factor user authentication and key agreement scheme in hierarchical wireless sensor networks. Secur Commun Netw 2016;9:2070–92. doi:10.1002/sec.1464.

Dodis Y, Reyzin L, Smith A. Fuzzy extractors: how to generate strong keys from biometrics and other noisy data, 38; 2004. p. 523–40. doi:10.1137/060651380.

Dolev D, Yao ACC. On the security of public key protocols. IEEE Trans Inf Theory 1983;29(2):198–208. doi:10.1109/SFCS.1981.32.

Esfahani A, Mantas G, Matischek R, Saghezchi FB, Rodriguez J, Bicaku A, Maksuti S, Bastos J. A lightweight authentication mechanism for m2m communications in industrial. IEEE Inter Things J 2017;PP:1–8. doi:10.1109/JIOT.2017.2737630.

Gomez C, Paradells J. Wireless home automation networks: a survey of architectures and technologies. IEEE Commun Mag 2010;48(6):92–101. doi:10.1109/MCOM.2010.5473869.

Han K, Kim J, Shon T, Ko D. A novel secure key paring protocol for rf4ce ubiquitous smart home systems. Person Ubiq Comput 2013;17:945–9. doi:10.1007/s00779-012-0541-2.

He D, Kumar N, Lee JH, Sherratt RS. Enhanced three-factor security protocol for USB mass storage devices. IEEE Trans Consum Electron 2014;60(1):30–7. doi:10.1109/TCE.2014.6780922.

He D, Zeadally S. Authentication protocol for an ambient assisted living system. IEEE Commun Mag 2015;53:71–7. doi:10.1109/MCOM.2015.7010518.

Hsieh WB, Leu JS. Anonymous authentication protocol based on elliptic curve Diffie–Hellman for wireless access networks. Wirel Commun Mobile Comput 2012;14(10):995–1006. doi:10.1002/wcm.2252.

Jeong J, Chung MY, Choo H. Integrated otp-based user authentication scheme using smart cards in home networks, 294; 2008. p. 1–7. doi:10.1109/HICSS.2008.208.

Jin M, Bekiaris-Liberis N, Weekly K, Spanos CJ, Bayen AM. Occupancy detection via environmental sensing. IEEE Trans Autom Sci Eng 2016;15:443–55. doi:10.1109/TASE.2016.2619720.

Jin M, Jia R, Spanos C. Virtual occupancy sensing: using smart meters to indicate your presence. IEEE Trans Mobile Comput 2017;16:3264–77. doi:10.1109/TMC.2017.2684806.
Kim HJ, Kim HS. Auth hotp–hotp based authentication scheme over home network environment, 6784; 2011. p. 622–37. doi:10.1007/978-3-642-21931-3_48.
Kocher P, Jaffe J, Jun B. Differential power analysis, 1666; 1999. p. 388–97. doi:10.1007/3-540-48405-1_25.
Kumar D, Chand S, Kumar B. Cryptanalysis and improvement of an authentication protocol for wireless sensor networks applications like safety monitoring in coal mines. J Ambient Intell Hum Comput 2018;10:641–60. doi:10.1007/s12652-018-0712-8.
Kumar P, Gurtov A, Iinatti J, Ylianttila M, Sain M. Lightweight and secure session-key establishment scheme in smart home environments. IEEE Sensors J 2015;16:254–64. doi:10.1109/JSEN.2015.2475298.
Li Y. Design of a key establishment protocol for smart home energy management system, PP; 2013. p. 88–93. doi:10.1109/CICSYN.2013.42.
Messerges T, Dabbish E, Sloan R. Examining smart-card security under the threat of power analysis attacks. IEEE Trans Comput 2002;51:541–52. doi:10.1109/TC.2002.1004593.
Mulder ED, Buysschaert P, Ors B, Delmotte P, Preneel B, Vandenbosch GAE, Verbauwhede I. Electromagnetic analysis attack on an FPGA implementation of an elliptic curve cryptosystem, 2; 2005. p. 1879–82. doi:10.1109/EURCON.2005.1630348.
Pradeep H, Singh S. Privacy preserving and ownership authentication in ubiquitous computing devices using secure three way authentication, PP; 2012. p. 107–12. doi:10.1109/INNOVATIONS.2012.6207712.
Santoso FK, Vun NCH. Securing IoT for smart home system, PP; 2015. p. 1–2. doi:10.1109/ISCE.2015.7177843.
Shnayder V, Hempstead M, rong Chen B, Allen W, Welsh M. Simulating the power consumption of large-scale sensor network applications. In: Proceedings of the second international conference on embedded networked sensor systems; 2004. p. 188–200.
Spreitzer R, Moonsamy V, Korak T, Mangard S. Systematic classification of side-channel attacks: a case study for mobile devices. IEEE Commun Surv Tutor 2017;PP:1–24. doi:10.1109/COMST.2017.2779824.
Suryadevara N, Mukhopadhyay S, Wang R, Rayudu R. Forecasting the behavior of an elderly using wireless sensors data in a smart home. Eng Appl Artif Intell 2013;26(10):2641–52. doi:10.1016/j.engappai.2013.08.004.
Vaidya B, Makrakis D, Mouftah HT. Device authentication mechanism for smart energy home area networks, 10(11); 2011a. p. 787–8. doi:10.1109/ICCE.2011.5722864.
Vaidya B, Park JH, Yeo SS, Rodrigues J. Robust one-time password authentication scheme using smart card for home network environment. Comput Commun 2011b;34:326–36. doi:10.1016/j.comcom.2010.03.013.
Wang D, Wang P. On the anonymity of two-factor authentication schemes for wireless sensor networks: attacks, principle and solutions. Comput Netw 2014a;73:41–57. doi:10.1016/j.comnet.2014.07.010.
Wang D, Wang P. Understanding security failures of two-factor authentication schemes for real-time applications in hierarchical wireless sensor networks. Ad Hoc Netw 2014b;20:1–15. doi:10.1016/j.adhoc.2014.03.003.
Wazid M, Das AK, Odelu V, Kumar N, Susilo W. Secure remote user authenticated key establishment protocol for smart home environment. IEEE Trans Depend Secure Comput 2017;PP:1–15. doi:10.1109/TDSC.2017.2764083.
Wu F, Li X, Sangaiah AK, Xu L, Kumari S, Wu L, Shen J. A lightweight and robust two-factor authentication scheme for personalized healthcare systems using wireless medical sensor networks. Future Gen Comput Syst 2018;82:727–37. doi:10.1016/j.future.2017.08.042.
Wu F, Xu L, Kumari S, Li X, Das AK, Khan MK, Karuppiah M, Baliyan R. A novel and provably secure authentication and key agreement scheme with user anonymity for global mobility networks. Secur Commun Netw 2016;9(16):3527–42. doi:10.1002/sec.1558.
Xiong L, Peng D, Peng T, Liang H, Liu Z. A lightweight anonymous authentication protocolwith perfect forward secrecy for wireless sensor networks. Sensors 2017;17:2681–709. doi:10.3390/s17112681.
Xu J, Xue K, Yang Q, Hong P. Psap: Pseudonym-based secure authentication protocol for NFC applications. IEEE Trans Consum Electron 2018;64(1):83–91. doi:10.1109/TCE.2018.2811260.
Xue K, Ma C, Hong P, Ding R. A temporal-credential-based mutual authentication and key agreement scheme for wireless sensor networks. J Netw Comput Appl 2013;36(1):316–23. doi:10.1016/j.jnca.2012.05.010.

Mengxia Shuai received the B.S. and M.S. degrees from Fuzhou University, Fuzhou, China. Currently, he is pursuing the Ph.D. degree at University of Science and Technology of China. His research interests include cryptography and information security.

Nenghai Yu received his B.S. degree in 1987 from Nanjing University of Posts and Telecommunications, M.E. degree in 1992 from Tsinghua University and Ph.D. degree in 2004 from University of Science and Technology of China, where he is currently a professor. His research interests include multimedia security, multimedia information retrieval, video processing, information hiding and security, privacy and reliability in cloud computing.

Hongxia Wang received the B.S. degree from Hebei Normal University, Shijiazhuang, China, in 1996, and the M.S. and Ph.D. degrees from University of Electronic Science and Technology of China, Chengdu, China, in 1999 and 2002, respectively. She pursued postdoctoral research with Shanghai Jiao Tong University, Shanghai, China, from 2002 to 2004 and was a visiting scholar with Northern Kentucky University, Highland Heights, KY, USA, from 2013 to 2014. She is currently a professor with the college of cybersecurity, Sichuan University, Chengdu. She has authored over 90 research papers in refereed journals and conferences, and holds nine authorized patents. Her research interests include multimedia information security, digital forensics, information hiding, and digital watermarking.

Ling Xiong received the M.S. and Ph.D. degrees from Southwest Jiaotong University, Chengdu, China. She is currently a lecturer with the school of computer and software engineering, Xihua University, Chengdu. Her research interests include the formal analysis of cryptographic protocol, the security and privcy in cloud computing services environment and wireless sensor networks environment.